

SIMATS ENGINEERING

ASSESSMENT TOOL 1 – REPORT ANALYSIS

Course: **Ethical Hacking (ITA14)** | Outcome: **CO2 (BT3)**

Total Marks: 50 | Duration: 90 min | Weightage: 30%

Student Name: B.Muni ChandiniReg. No: 192524283

Question 1: Nmap Network Scan Analysis

Scenario: A security analyst performed a network scan on the target 192.168.1.10 using Nmap. The report identified open ports HTTP (80), SSH (22), and MySQL (3306), along with the operating system and service versions.

1.1 Report Interpretation & Key Findings

The Nmap scan reveals a significantly exposed attack surface on the target host. The following key findings are identified:

- **Open Port 80 (HTTP):** Web service is running and publicly reachable. Version detection typically reveals the web server software (e.g., Apache, Nginx, IIS) and version number.
- **Open Port 22 (SSH):** Secure Shell service is enabled, allowing remote command-line access. Banner grabbing often discloses OpenSSH version and supported algorithms.
- **Open Port 3306 (MySQL):** Database service is listening on the default port and is network-accessible. This is a critical finding as databases should rarely be exposed beyond trusted networks.
- **OS & Service Version Detection:** Nmap's OS fingerprinting and service version probes provide attackers with precise software versions, enabling them to map known CVEs and public exploits.

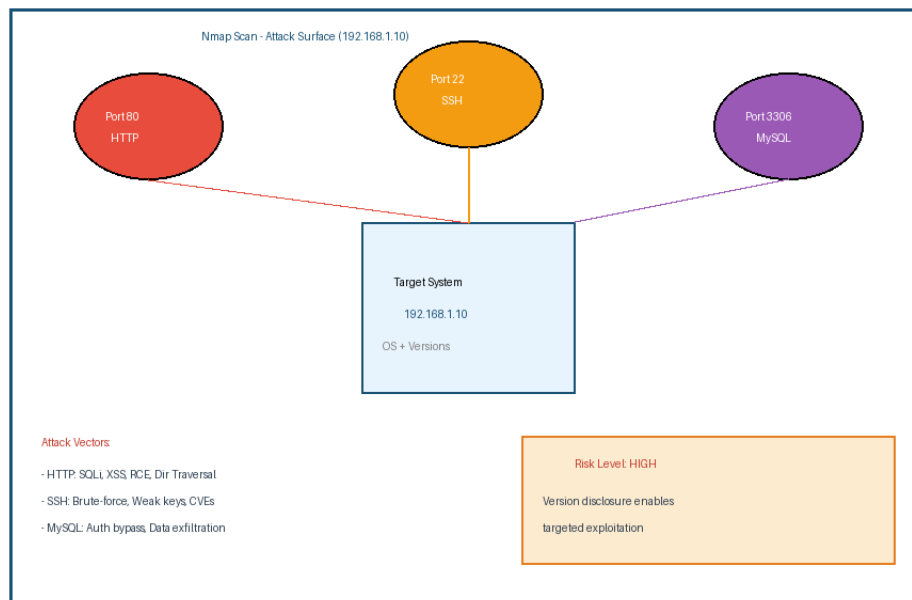


Figure 1: Nmap Scan Results – Attack Surface & Risk Overview

1.2 Security Risks Associated with Identified Services

HTTP (Port 80)

- Unencrypted traffic – credentials and session tokens can be intercepted via MITM attacks.

- Common web vulnerabilities: SQL Injection, Cross-Site Scripting (XSS), Remote Code Execution (RCE), Local/Remote File Inclusion, Directory Traversal.
- Outdated web server or application frameworks often contain publicly known CVEs that can be exploited with Metasploit or custom scripts.
- Information disclosure through server headers, error pages, and default pages aids further reconnaissance.

SSH (Port 22)

- Brute-force and credential stuffing attacks against weak or default passwords.
- Exploitation of known OpenSSH vulnerabilities (e.g., older versions susceptible to user enumeration or remote code execution).
- Weak cryptographic algorithms or host key reuse can enable man-in-the-middle attacks.
- Once access is obtained, the attacker gains a foothold for privilege escalation and lateral movement.

MySQL (Port 3306)

- Direct database exposure is a critical risk – attackers can attempt authentication bypass, brute-force, or exploit known MySQL vulnerabilities.
- Successful access leads to data exfiltration, modification, or destruction of sensitive records.
- Weak or default MySQL accounts (root with no password, anonymous users) are frequently targeted.
- SQL injection from the web application can be chained with direct DB access for deeper compromise.

1.3 How an Attacker Could Exploit These Services

A typical attacker workflow would be:

1. **Reconnaissance:** Use Nmap results + service banners to identify exact versions and search CVE databases / Exploit-DB.
2. **Web Exploitation:** Scan the HTTP service with tools such as Nikto, Dirb/Gobuster, and Burp Suite. Exploit identified web vulnerabilities to gain initial access or extract credentials.
3. **SSH Access:** Perform password spraying or dictionary attacks (Hydra, Medusa). Alternatively, use stolen credentials obtained from web compromise.
4. **Database Compromise:** Connect directly to MySQL (mysql client or Metasploit modules) using default/weak credentials or credentials recovered from configuration files on the web server.
5. **Post-Exploitation:** Escalate privileges, install persistence (backdoors, scheduled tasks), and move laterally within the internal network.

1.4 Recommended Security Measures

- **Network Segmentation & Firewalling:** Restrict port 3306 to application servers only. Place database behind a firewall; never expose it to the internet. Limit SSH access to management jump hosts or VPN.
- **Disable Unnecessary Services:** If a service is not required, stop and disable it. Prefer HTTPS (443) over plain HTTP and enforce HSTS.
- **Patch & Version Management:** Keep OS, web server, SSH daemon, and MySQL updated. Subscribe to vendor security advisories.
- **Strong Authentication:** Enforce key-based SSH authentication (disable password auth). Use strong, unique passwords and multi-factor authentication where possible. Rotate database credentials regularly.
- **Web Application Security:** Deploy a Web Application Firewall (WAF). Perform regular vulnerability assessments and secure coding practices (input validation, parameterized queries).
- **Banner Suppression & Hardening:** Minimize service banners, disable version disclosure, implement fail2ban / rate limiting for SSH, and apply principle of least privilege on all accounts.
- **Monitoring & Logging:** Enable detailed logging for SSH, web server, and MySQL. Forward logs to a SIEM and configure alerts for brute-force attempts and anomalous queries.

Question 2: Phishing Awareness Campaign Analysis

Scenario: A phishing awareness campaign was conducted for employees of ABC Technologies Pvt. Ltd. using the GoPhish tool. Results: 40% of employees clicked the phishing link, 20% entered their login credentials, and several users downloaded a malicious attachment.

2.1 Report Interpretation

The campaign results indicate a high susceptibility to social engineering among the workforce:

- **40% Click Rate:** Nearly half the employees interacted with a suspicious link, demonstrating weak email hygiene and insufficient verification habits.
- **20% Credential Submission:** One in five employees willingly entered credentials on a fake login page – a direct path to account takeover.
- **Malicious Attachment Downloads:** Users demonstrated trust in unexpected email attachments, creating a pathway for malware (ransomware, RATs, credential stealers) to enter the corporate network.

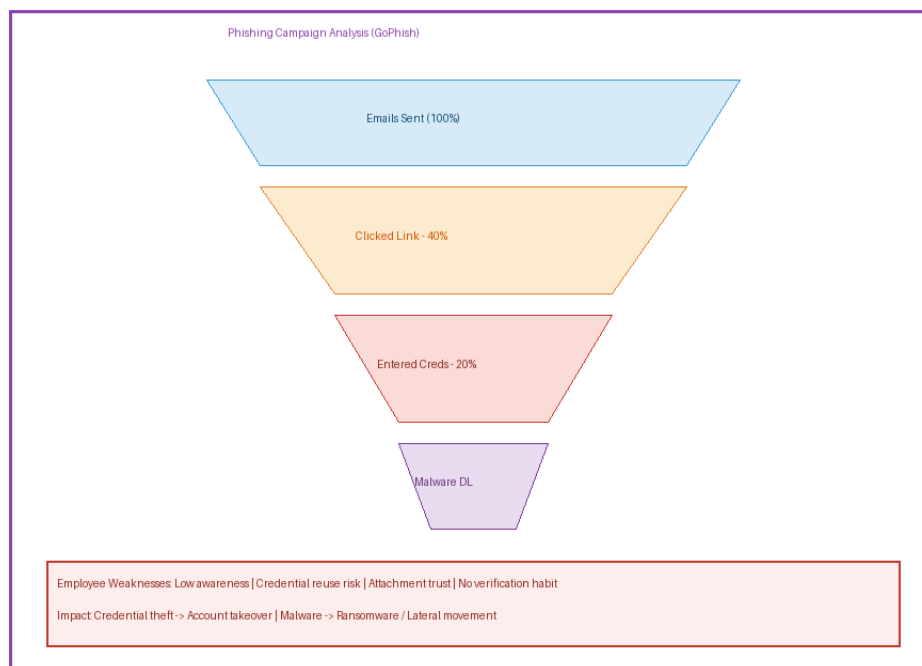


Figure 2: Phishing Campaign Conversion Funnel (GoPhish Results)

2.2 Security Weaknesses Demonstrated by Employees

- **Lack of Phishing Awareness:** Employees failed to recognize common indicators (urgent language, mismatched sender domains, unexpected links/attachments).
- **Poor Link Hygiene:** Clicking links without hovering to inspect the real URL or verifying the sender through an alternate channel.
- **Credential Trust:** Entering corporate credentials on untrusted pages shows absence of “verify before you supply” mindset.
- **Attachment Curiosity:** Opening or downloading unexpected files indicates inadequate understanding of malware delivery vectors.
- **Absence of Reporting Culture:** High engagement rates suggest employees did not report the suspicious email to the security team before interacting.

2.3 Recommended User Awareness Programs

- **Regular Simulated Phishing Exercises:** Conduct quarterly GoPhish (or similar) campaigns with progressive difficulty. Provide immediate feedback and micro-training to users who fail.
- **Interactive Security Awareness Training:** Mandatory annual training covering phishing, spear-phishing, vishing, smishing, and business email compromise (BEC). Include real-world case studies.
- **Just-in-Time Education:** Display short security tips when users open external emails or click links for the first time.
- **Role-Based Training:** Provide advanced training for high-risk roles (finance, HR, executives) who are frequent targets of BEC and spear-phishing.

2.4 Email Security Controls

- **SPF, DKIM, DMARC:** Implement and enforce strict DMARC policy (p=reject) to prevent domain spoofing.
- **Advanced Email Gateway / Anti-Phishing:** Deploy solutions that perform URL rewriting, attachment sandboxing, and AI-based phishing detection.
- **Banner Warnings:** Automatically tag external emails with a clear “EXTERNAL” banner.
- **Attachment & Link Controls:** Block high-risk file types (.exe, .js, .vbs, .hta) and require user confirmation for macro-enabled documents.
- **MFA Everywhere:** Enforce multi-factor authentication so stolen passwords alone cannot grant access.

2.5 Organizational Policies

- **Acceptable Use & Email Policy:** Clearly define expected behaviour regarding links, attachments, and credential entry.
- **Incident Reporting Procedure:** Simple, non-punitive process (e.g., “Report Phish” button) with rapid response from the security team.
- **Consequence Framework:** Repeat offenders of simulated phishing should receive mandatory coaching; severe or intentional violations may trigger formal HR action.
- **Continuous Improvement:** Track metrics (click rate, report rate, time-to-report) and adjust training content accordingly. Celebrate improvement to reinforce positive behaviour.

Question 3: DNS Zone Transfer Assessment (10 Marks)

Scenario: A DNS assessment report generated using the Dig tool shows that the organization’s DNS server permits a successful DNS Zone Transfer (AXFR), exposing internal hostnames, mail servers, and DNS records.

3.1 Report Interpretation & Security Implications

A successful AXFR response means any host that can reach the DNS server on TCP port 53 can obtain a complete copy of the zone file. The exposed information typically includes:

- Complete list of internal hostnames and their IP addresses.
- Mail exchanger (MX) records revealing mail server infrastructure.
- Service records (SRV), CNAME aliases, and TXT records (possibly containing SPF or verification tokens).
- Naming conventions that often disclose system roles (e.g., db-prod-01, vpn-gw, hr-portal).

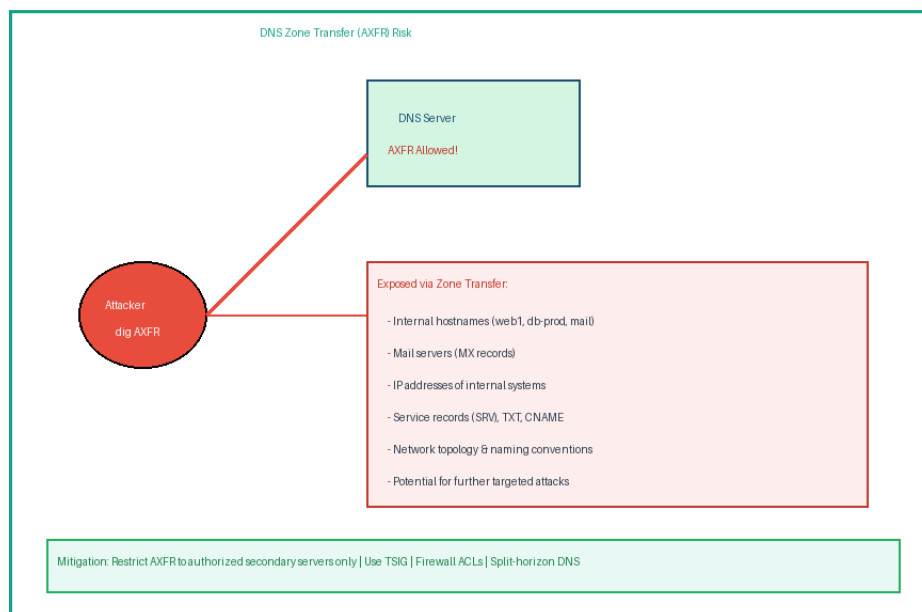


Figure 3: DNS Zone Transfer (AXFR) Exposure & Impact

3.2 How Attackers Could Exploit These Findings

- **Network Mapping:** Build an accurate internal topology without scanning, reducing noise and detection risk.
- **Target Selection:** Identify high-value systems (domain controllers, databases, mail servers, VPN gateways) for focused attacks.
- **Spear-Phishing Enhancement:** Craft highly credible phishing emails using real internal hostnames and employee naming patterns.
- **Subdomain Takeover / DNS Rebinding:** Discover abandoned or misconfigured records that can be claimed.
- **Further Enumeration:** Combine zone data with other passive sources (certificate transparency, public Git repos) for deeper reconnaissance.

3.3 Best Practices to Secure DNS Infrastructure

- **Restrict Zone Transfers:** Configure the primary DNS server to allow AXFR only from explicitly authorized secondary name servers (IP-based ACLs).
- **Use TSIG (Transaction Signatures):** Authenticate zone transfers with shared cryptographic keys so only trusted secondaries can request them.
- **Split-Horizon / Split-View DNS:** Serve different zone data to internal versus external clients so internal hostnames never appear in public responses.
- **Firewall DNS Ports:** Allow TCP/UDP 53 only from required sources. Block AXFR requests originating from untrusted networks.
- **Minimize Public Records:** Publish only the records that must be publicly resolvable. Keep internal systems in a private zone.
- **Monitoring & Auditing:** Log all zone-transfer attempts and alert on unauthorized AXFR requests. Regularly review DNS configuration as part of security assessments.

Code of Conduct

I B.Muni Chandini (192524283) (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: B.Muni Chandini